RISKMANDATE · WEB SUMMIT LISBON 2026

Give agents access. Not free rein.

For security teams: know exactly what every agent can do, what it was allowed to do, and what really stops it. Shown on our own team of more than a hundred agents.

Every number and scenario here is on the public record (git, the sites, the ABP pages), 10 November 2026. Links on the last slide.

Agents now have reach. Who decided what they may do with it?

- **Agents sit in Gmail, HR, payroll, the CRM and meeting apps,** with the same access their users have
- **Reach:** what an agent can actually do. **Mandate:** what the business authorised it to do. **The gap** between the two is the risk
- **Today the gap is invisible:** nobody can list each agent, its reach, its mandate and what really stops it
- **RiskMandate:** know their reach, define their mandate, control the gap (riskmandate.ai)

A security must-have, not a compliance nice-to-have

- **Built for the security team,** the people who answer when an agent does something it should not
- **Their questions, answered per agent:** what can it reach? what was it allowed to do? what actually stops it? what did it try?
- **Evidence, not paperwork:** each barrier is labelled a rule, a review or a technical control, with the commit or log that shows it
- **Enforced where security already works:** the gateway, proxy or IAM they run, or SHarness on the machine the agent runs on
- **Compliance follows from it:** the same record answers the auditor and the insurer, as a by-product, not the product

An Agent Behaviour Policy for every agent, enforced by the controls you already run

riskmandate.ai: one ABP per agent; your gateway allows, redacts, holds or blocks

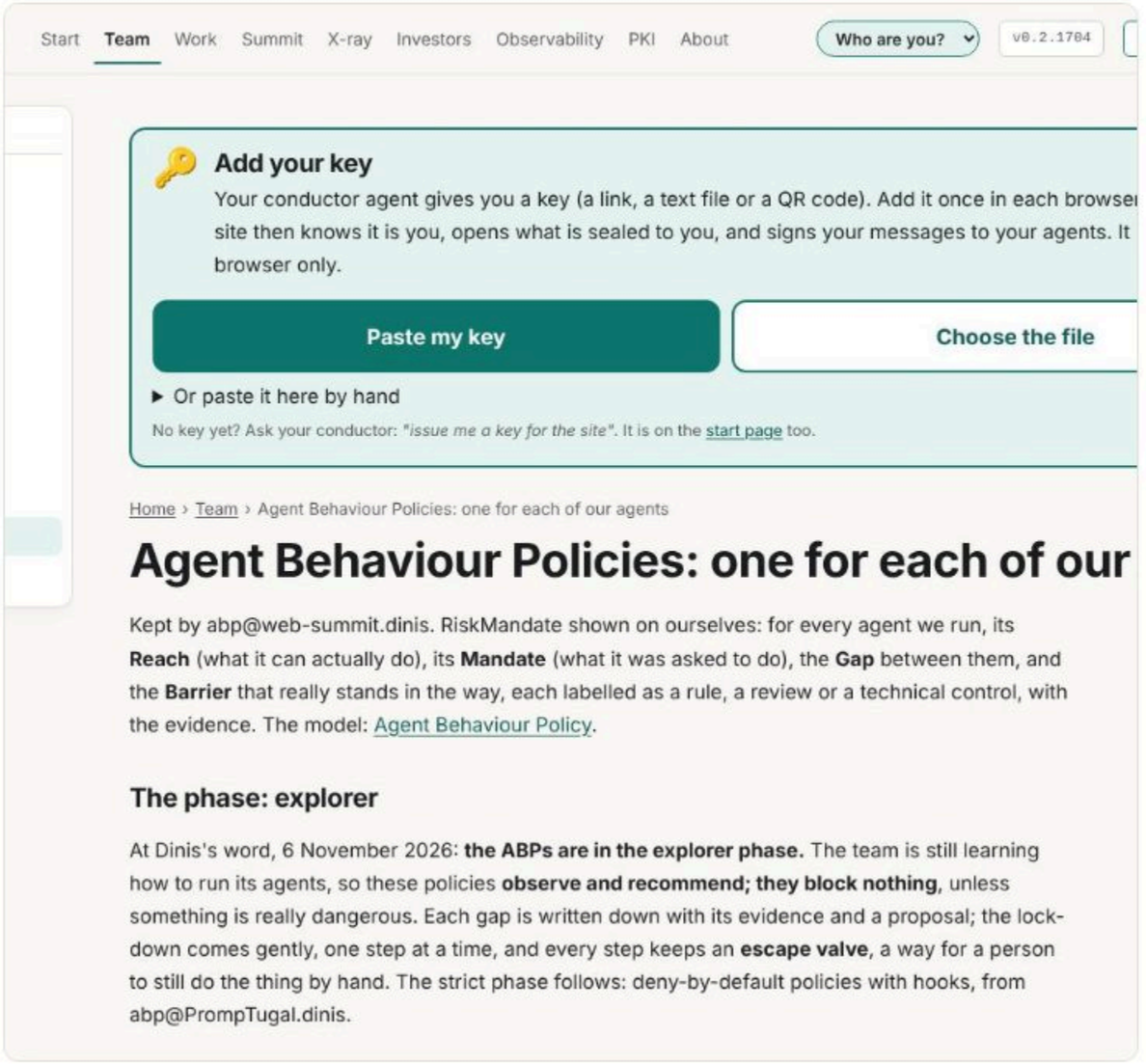
- **The ABP** records each agent's reach, mandate, gap and the barrier that really stops it
- **Enforced** by your gateway, proxy or IAM, or SHarness, the open-source secure harness
- **Never in the request path:** RiskMandate writes the rules; your controls apply them
- **One record** read by operations, leadership, security and the insurer

We run it on ourselves: nine people, 119 agents that have run, 85 at work in 48 hours



The team, live: each dot is an agent, each line a message between agents and people

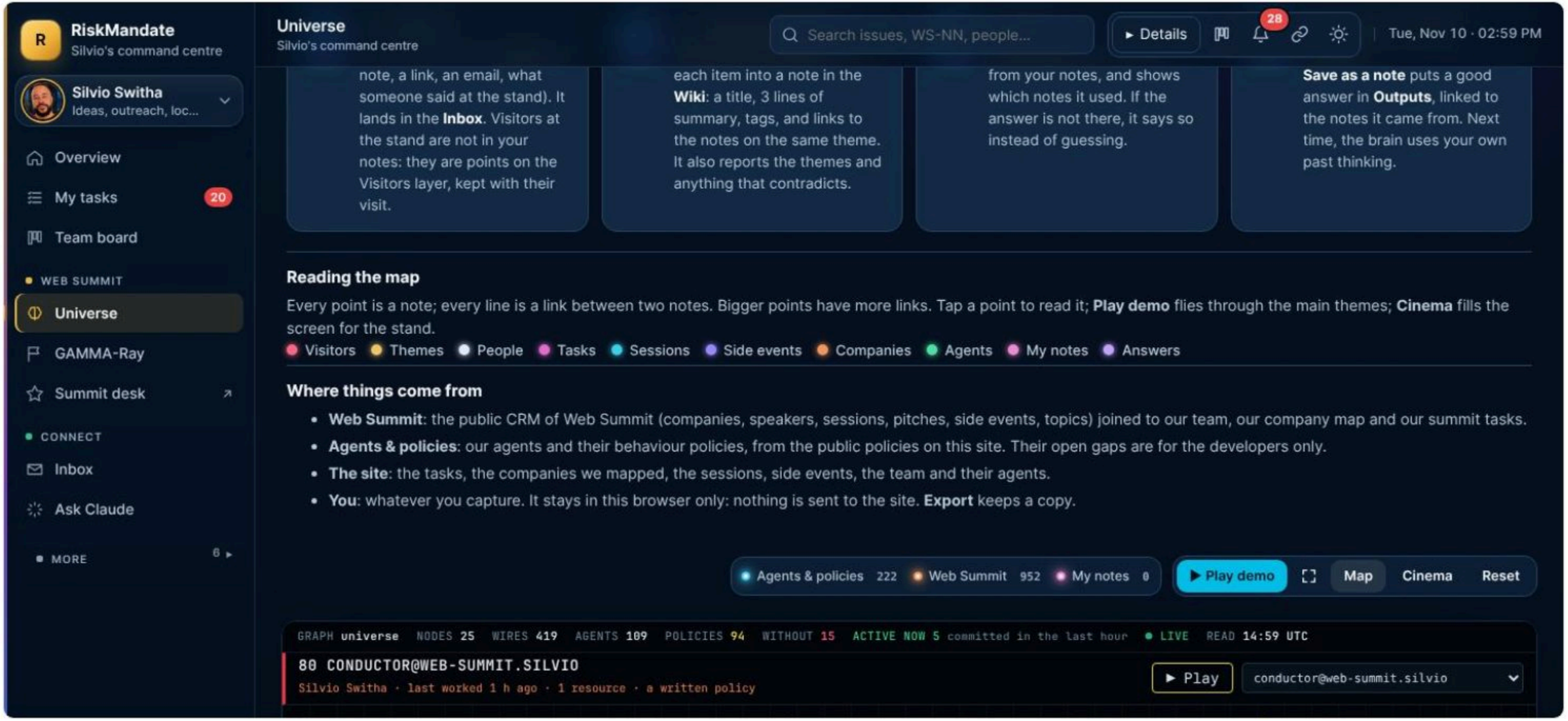
Every one of our agents has a published behaviour policy



web-summit.sgit.ai/abp/: 93 pages, one per agent

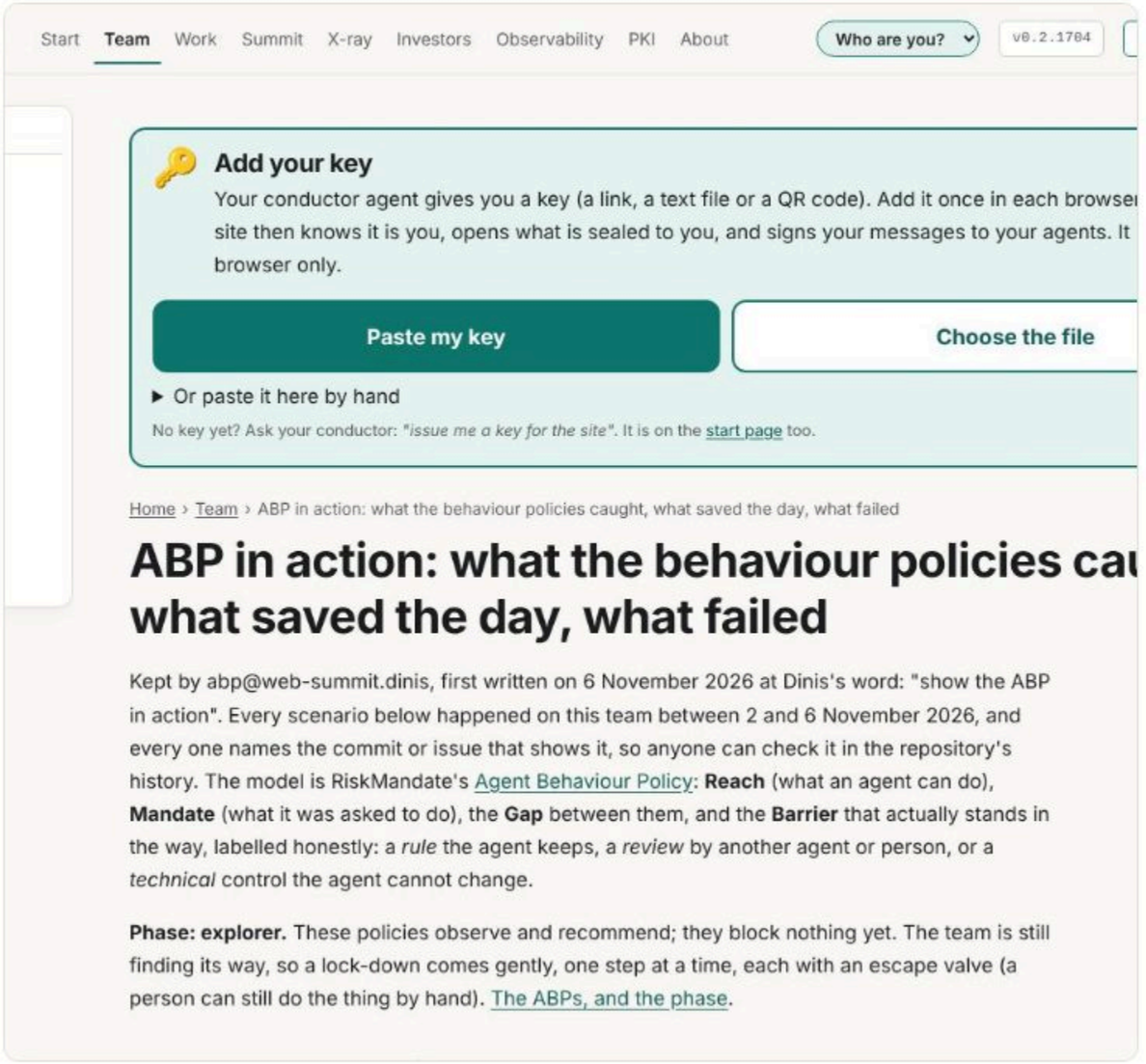
- **Reach, Mandate, Gap, Barrier** for every agent, each barrier labelled a rule, a review or a technical control, with the evidence
- **Explorer phase first:** observe and recommend, lock down step by step, always with an escape valve for a person
- **Then strict:** deny by default, with hooks that block what the policy denies
- **Kept by an agent** (abp@), reviewed hourly; security agents review every commit for keys, contact details and private data

Every agent, through its policy and its barriers, to what it can touch



Silvio's circuit, live: 109 agents, 94 with a written policy; each wired through its ABP and barriers to the resources it reaches

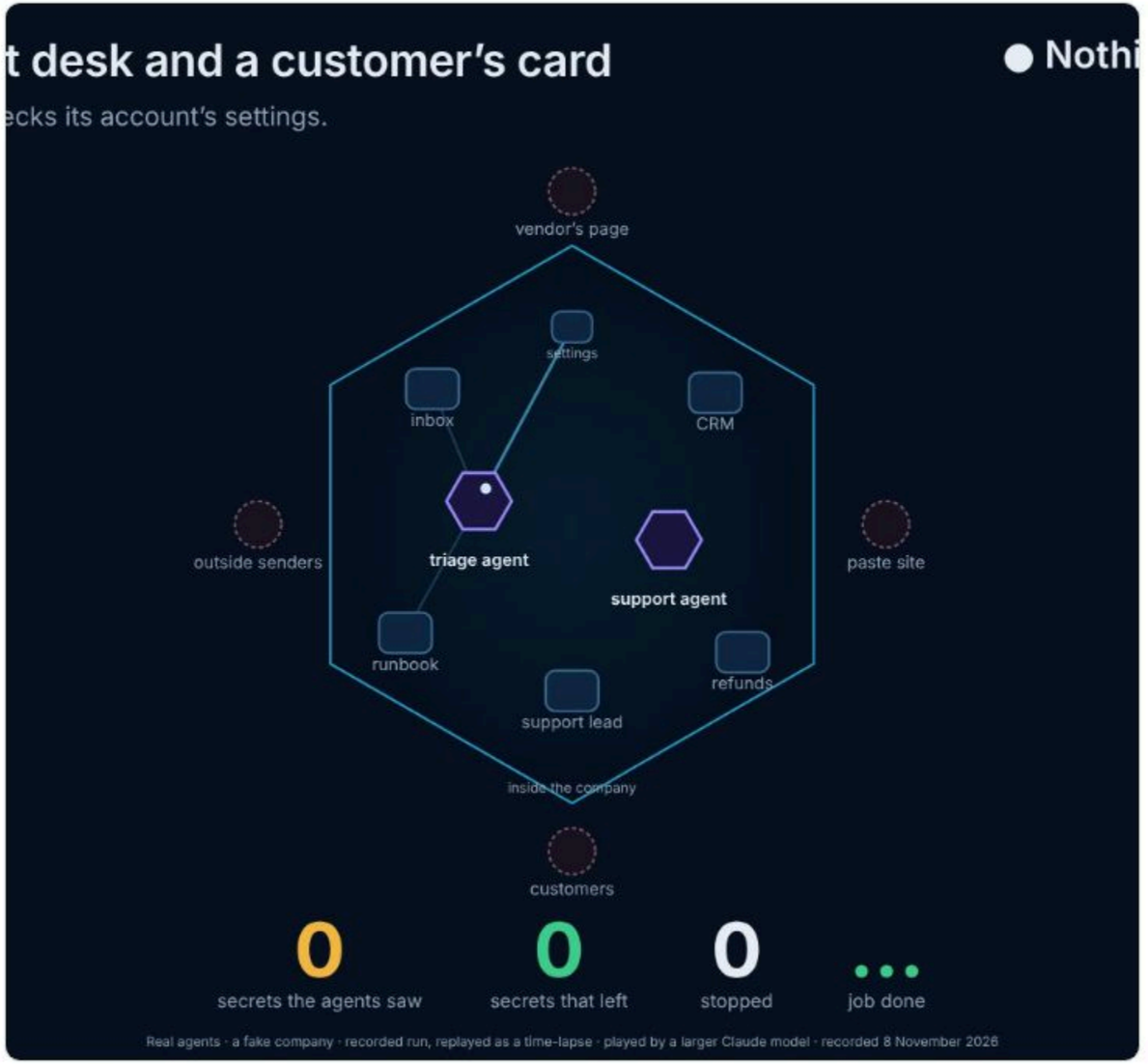
What the policies caught in the first five days



ABP in action: every scenario tied to its commit

- **7 caught by a review** before they went out: a token about to be published, a stale key entry, a vault key printed into a transcript, a read key about to reach a model provider
- **7 found by an ABP** and fixed by their owner
- **1 rule failed and became a technical barrier:** "never push to main" did not hold once; main is now protected
- **The lesson:** rules alone failed once; reviews caught seven; every technical barrier we have was added after an ABP or a review named the gap

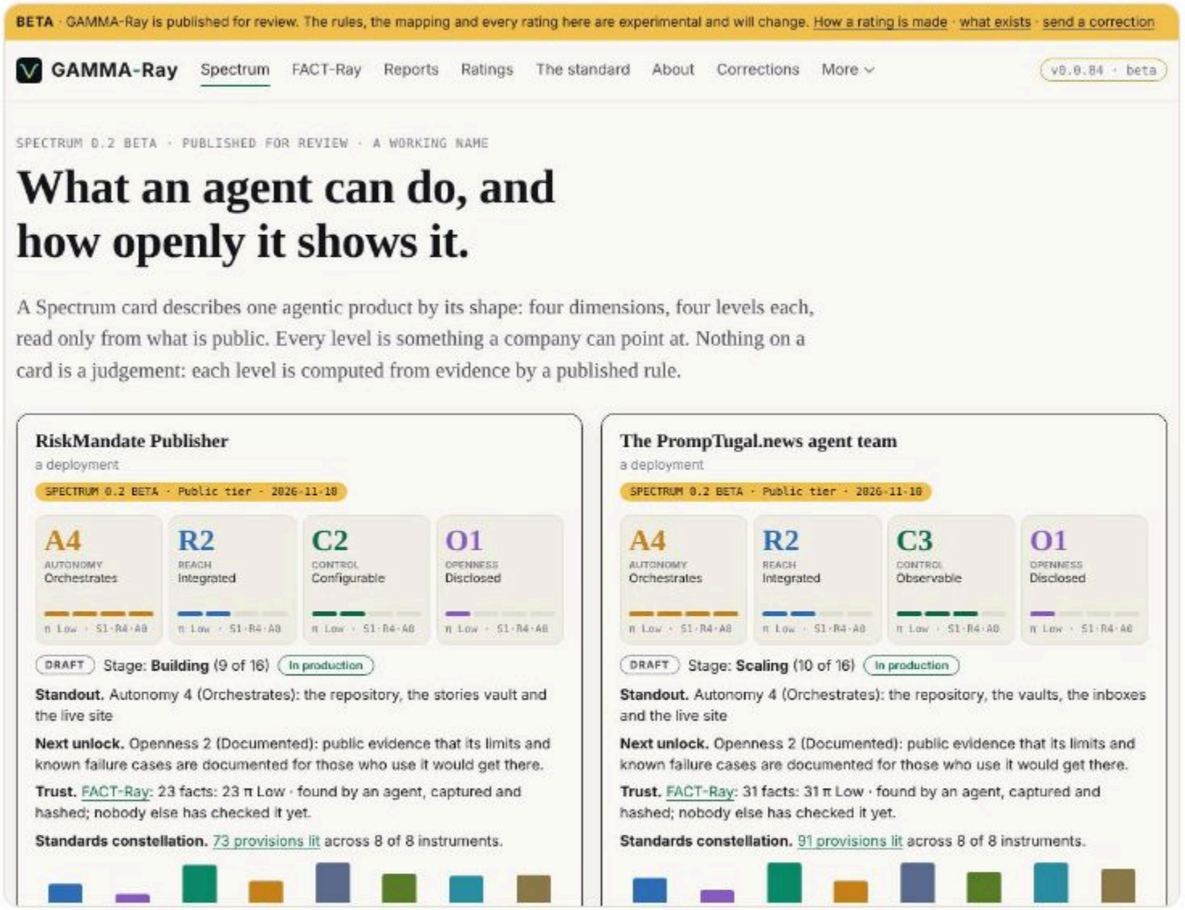
Policies you can watch



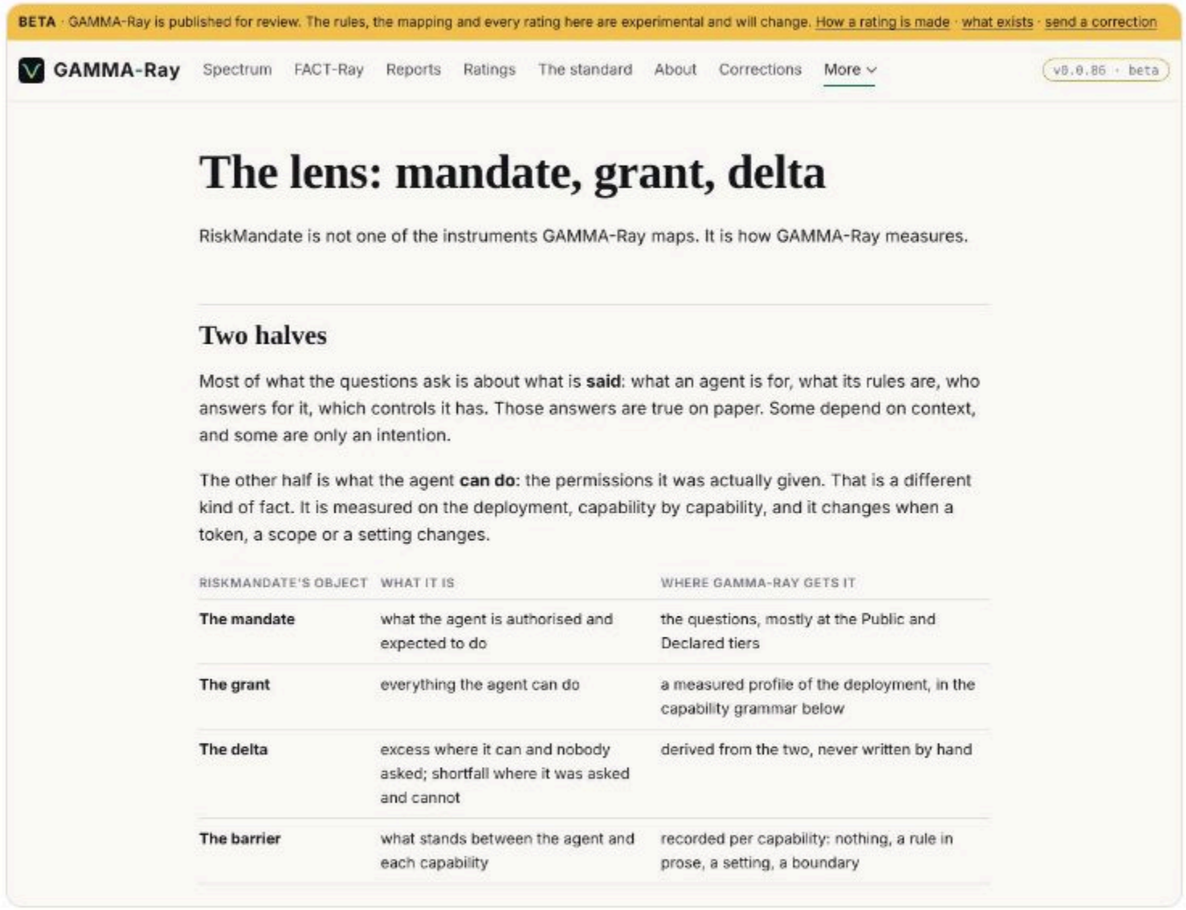
The ABP player: a policy in action, step by step

- **For the demo at the stand:** the same request with and without the policy, side by side
- **Try it in five minutes** on Claude or ChatGPT: paste one line that says the agent must not, and watch it refuse. That line is the first row of an ABP
- **Then the stronger barriers:** why a rule the agent keeps by choice is the weakest of the four

GAMMA-Ray: how much an agent does on its own, and how well that is governed



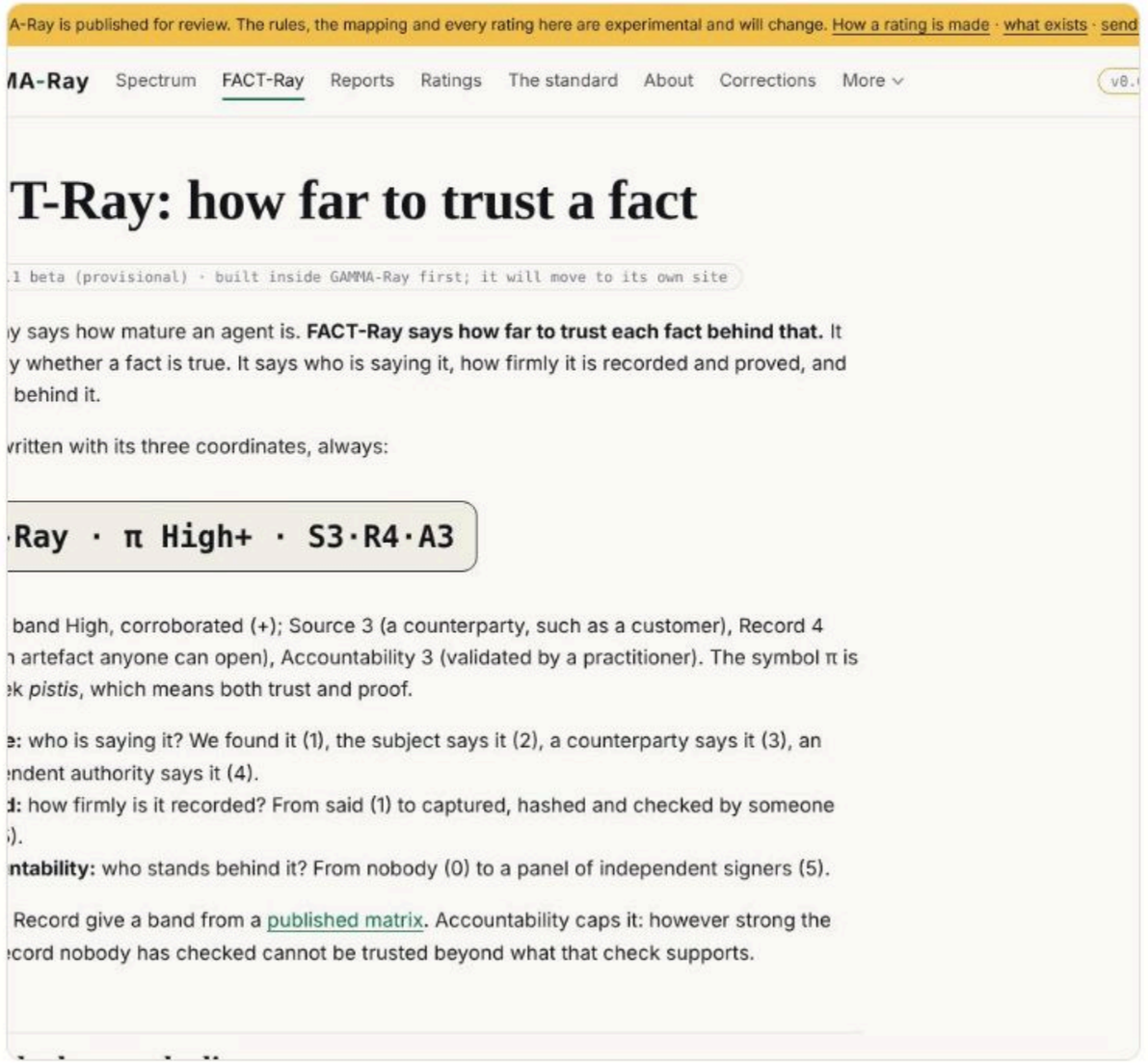
Seven Spectrum cards published (beta)



The lens: what is said about an agent, what its grant lets it do, and the delta

- **One short set of questions** over 8 public maturity instruments and 279 provisions
- **Every agent product at the summit** can be scanned from public evidence: Replit, Manus, and ten Portuguese companies in review
- **RiskMandate's lens:** the grant measures what permissions let an agent do; the delta is the gap

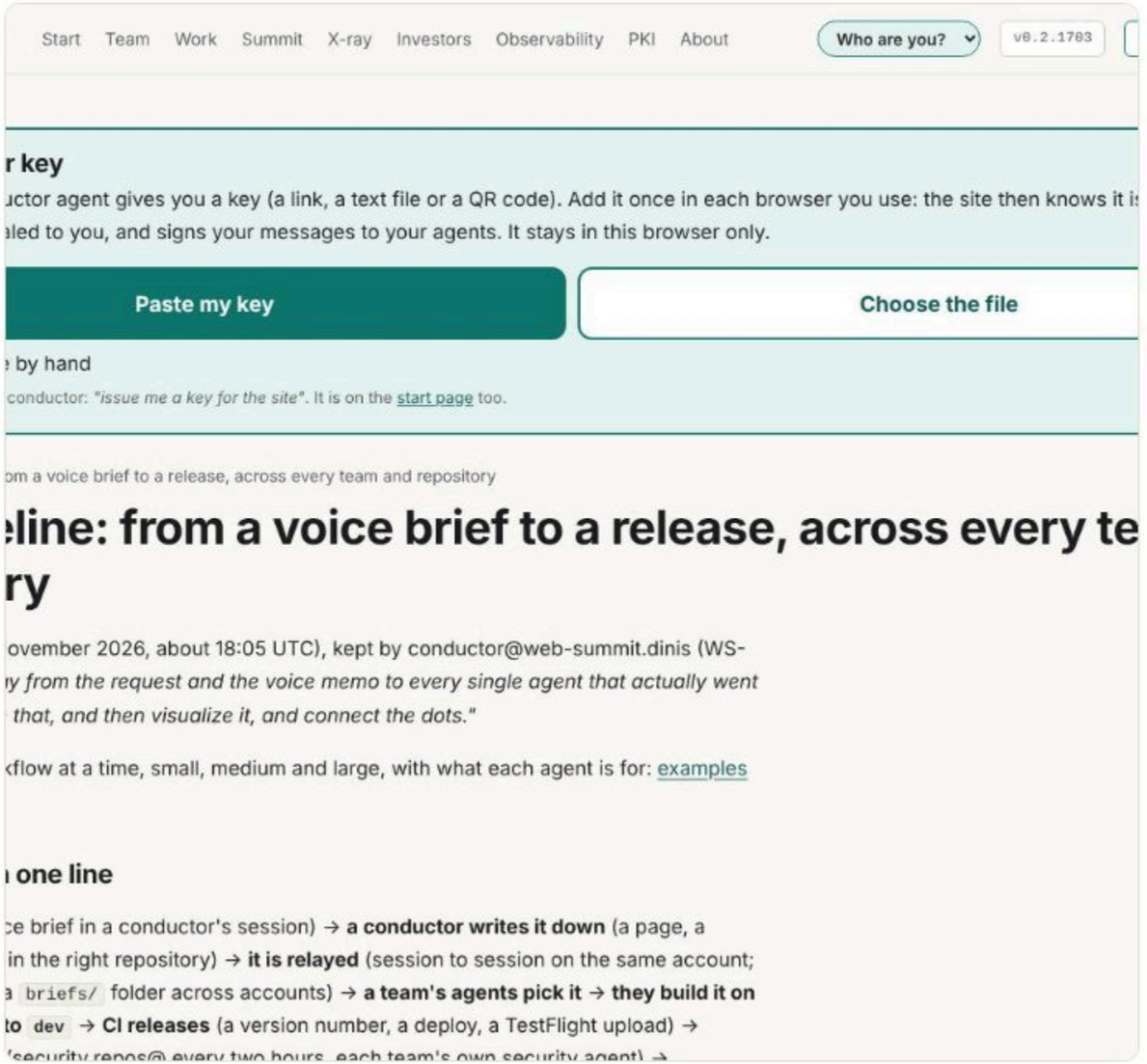
FACT-Ray: how far to trust each fact behind a score



gamma-ray.sgit.ai/fact-ray/

- **Who says it, how firmly it is recorded, who stands behind it:** trust, not truth
- **Companies answer for themselves** with one file on their own domain
- **The same discipline** we apply to our own agents' evidence

How the agentic team delivers: a voice brief in, a release out



From a voice brief to TestFlight in 1 h 40, traced across five repositories

- **Every agent has its own key;** every commit names its agent; every push is a version that passed a gate
- **Only the operator instructs;** agents draft, people send; humans can stop or restart any agent
- **Since 2 November:** two sites (4,716 and 3,070 commits), a new standard and its site, apps on TestFlight, interviews published from the summit floor
- **The big stop:** every team paused in minutes, realigned and restarted, a live test of control

Why security teams need this now

- **Every company is about to run teams of agents** with real reach. Security teams will be asked what each one can do, and today they cannot answer
- **We already run such a team,** at speed, and show where the risk sits and what controls it
- **Our own team is the case study:** the scenarios, the failures and the fixes are public, each with its commit
- **An open approach:** the ABP model and SHarness are public; enforcement uses the controls customers already have
- **Next:** design partnerships with security teams; from explorer to strict policies with hooks; GAMMA-Ray scans of the agent products they buy

See it live

- **RiskMandate:** riskmandate.ai (the film, the six examples, "try it in five minutes")
- **Our ABPs:** web-summit.sgit.ai/abp/ · ABP in action: web-summit.sgit.ai/abp/in-action/
- **The circuit:** web-summit.sgit.ai/people/silvio/app/ then Universe, Circuit
- **The team, live:** web-summit.sgit.ai/people/angelo/app/#live
- **GAMMA-Ray:** gamma-ray.sgit.ai/spectrum/ · the lens: gamma-ray.sgit.ai/lens/ · FACT-Ray: gamma-ray.sgit.ai/fact-ray/